

TriageCounsel — Customer DPO Annex

Document: Data Protection Officer / Privacy Team Annex

Version: 1.1

Last updated: September 2026

Service: TriageCounsel (triagecounsel.com)

This annex supports vendor diligence and DPA review. It supplements the [Subprocessors page](#), [Privacy Policy](#), and any executed customer agreement. It does not constitute legal advice.

1. Service and role

Item	Detail
Service provider (trade name)	TriageCounsel
Service description	SaaS contract review platform: deterministic policy engines, playbook comparison, review workflow, and optional AI-assisted explanation and evidence discovery
Typical GDPR role	Processor for customer-uploaded contract content and related account data, acting on documented instructions from the customer (Controller). TriageCounsel may act as Controller for its own account management, billing, and product analytics
Controller confirmation	Final role allocation is set out in the executed DPA
Legal entity	Operating entity name and registered address are stated in the customer DPA and on the public Privacy Policy once LLC registration is complete

2. Subprocessor register

Production subprocessors as of the date above:

Subprocessor	Purpose	Processing location	Customer / contract content
Hetzner Online GmbH	Infrastructure hosting (application, database, cache)	Germany (EU)	Yes — stored encrypted at rest
OpenAI, L.L.C.	AI-assisted analysis features (see §5)	United States and other OpenAI API regions	Yes — scope varies by feature
Stripe, Inc.	Payment processing and subscriptions	United States and other Stripe regions	No — billing metadata only
Google LLC	Optional sign-in (OAuth: openid, email, profile)	United States and other Google regions	No

SMTP email provider	Transactional email (password reset, account notifications) — production uses SMTP	United States and other locations used by the configured SMTP host	No
---------------------	---	--	----

Notes:

- PostgreSQL and Redis run on Hetzner-hosted infrastructure — not separate third-party database SaaS.
- **Automated server backups** are enabled on Hetzner Cloud (see §8).
- Original uploaded file bytes (PDF/DOCX) are **not** persisted to object storage or any file-hosting subprocessor.

Public register: <https://triagecounsel.com/security/subprocessors>

3. Categories of data

3.1 Account and authentication

Email, name, company, password hash, optional Google authentication identifiers, optional MFA configuration, subscription/plan metadata, Stripe customer identifiers.

3.2 Customer content (confidential)

Extracted contract text; deterministic findings; policy decisions and deviations; AI-generated explanations; playbook templates and configured positions; optional share-link settings.

Not stored: Original uploaded PDF/DOCX bytes (processed transiently in memory for text extraction only).

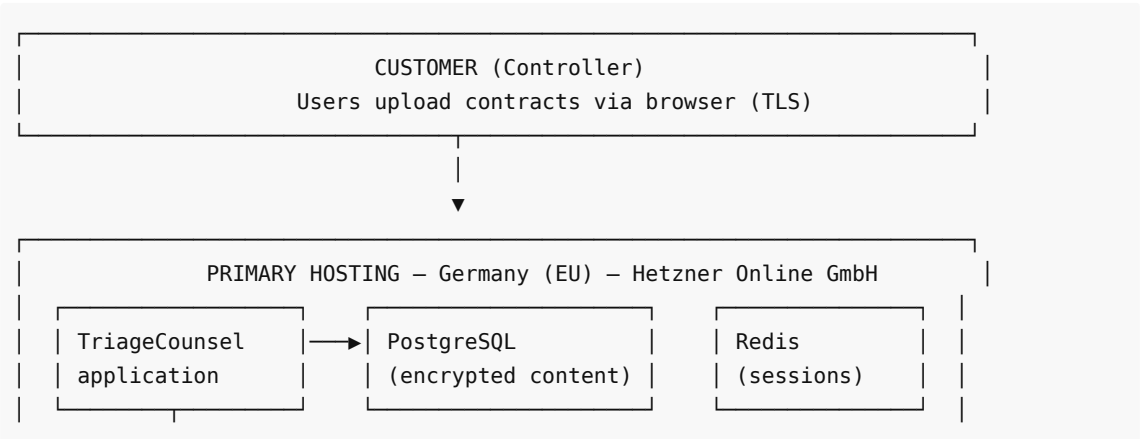
3.3 Operational and security

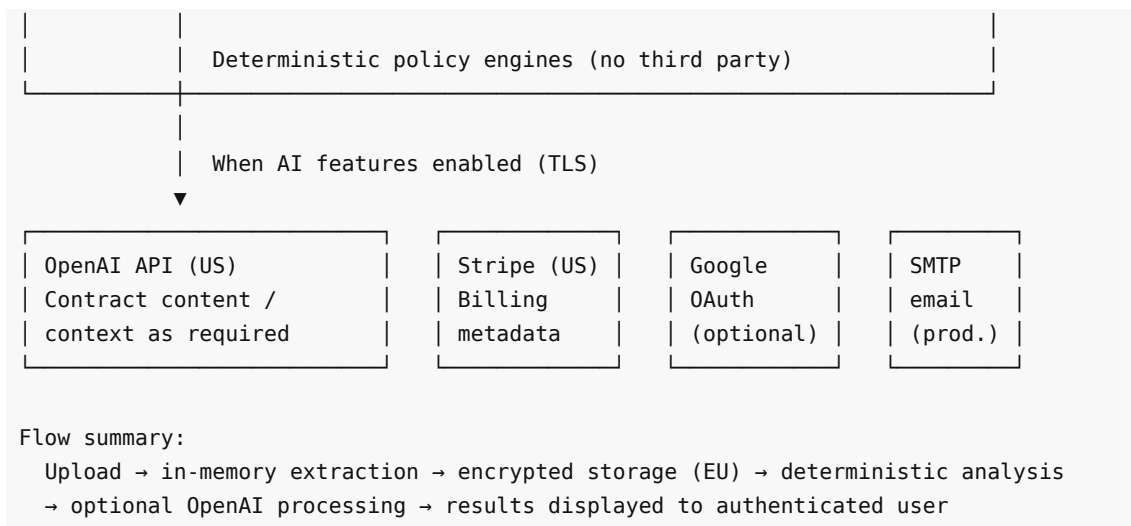
IP address, user agent, session and signup metadata (referrer, UTM parameters, coarse geo where derived), upload metadata (filename, file hash, size, processing time), append-only audit log entries.

3.4 Billing

Billing contact details and subscription status via Stripe. Payment card data is collected **directly by Stripe** — not stored by TriageCounsel.

4. High-level data-flow diagram





5. AI processing scope

OpenAI is the **only** subprocessor that receives contract content. Policy outcomes and risk scores are computed **outside** the AI.

Feature path	What may be sent to OpenAI	AI authority
Plain-language explanation	Deterministic findings (rule IDs, severities, matched excerpts, rationale)	Explains only; cannot change scores or policy outcomes
Fact admission / semantic discovery	Document text required for evidence verification; depending on configuration, this may include substantial portions or the full contract	Proposes/verifies evidence only; fail-closed on errors; outcomes decided by policy engines
AI-assisted playbook import	Full document text the customer chooses to upload (operator opt-in + user action)	Produces draft proposals only; active policy requires human approval

Scope varies by configuration: OpenAI may receive content ranging from **short excerpts to full document text**, depending on enabled features and production settings (e.g. fact-admission mode).

Training: Customer data is not used to train models by TriageCounsel. OpenAI API usage is subject to OpenAI's standard API terms (no training on API inputs).

6. Storage location

Data	Primary location at rest
Customer content (extracted text, analysis, playbooks)	Germany (EU) — Hetzner Online GmbH
Account, audit, and analytics data	Germany (EU) — same production environment
OpenAI processing	United States (and other OpenAI API regions per OpenAI)

Stripe / Google / SMTP email data	Per respective provider regions (primarily US)
-----------------------------------	--

There is no separate third-party object store for customer documents.

7. Encryption and security controls

Control	Implementation
Encryption at rest	AES-256-GCM for contract text and analysis JSON; key rotation supported
Encryption in transit	TLS (HTTPS) for all customer and subprocessor communication
Passwords	PBKDF2-HMAC-SHA256; never stored in plaintext
MFA	Optional TOTP (authenticator app); MFA secret encrypted at rest
Tenant isolation	Account-scoped queries; cross-customer access blocked by design and covered by automated tests
Upload security	File-type validation, size limits, sanitization; original bytes not written to disk
Audit logging	Append-only log of login, upload, delete, export, share, and admin events
Share links	Optional password, expiry, view limits, revocation; access logged
Secrets	API keys and encryption keys held in environment/secrets management only

Further detail: <https://triagecounsel.com/security>

8. Retention and deletion

Data type	Default retention	Deletion mechanism
Contract text and analysis	While account is active, until user deletes	Hard delete per contract; audit event recorded
Playbooks	While account is active	Deleted with account or individually
Account data	Until account deletion	Hard delete removes contracts and playbooks
Optional auto-retention	Off by default	Operator may configure maximum contract age for automated deletion
Audit and analytics	May persist after content deletion	Security/operational records retained for investigation and compliance
Hetzner automated	Up to 7 days	Enabled on production server; 7-slot rotation — when all slots are full, the oldest backup is replaced by the next automated

backups		backup. Deleted application data may therefore persist in backups for up to approximately seven days
Stripe records	Per Stripe retention	Not automatically deleted on account deletion — cancel subscription separately

Users may permanently delete individual contracts or their entire account from account settings.

9. International transfers

Primary storage of customer content is in the **European Union (Germany)**.

Transfers outside the UK/EEA occur when subprocessors in the United States (or other jurisdictions) process data:

Recipient	Typical transfer	Mechanism
OpenAI	Contract content for AI features	OpenAI DPA, including SCCs as amended by the UK Addendum for UK Data, as applicable
Stripe	Billing data	Stripe DPA / SCCs
Google	Authentication (if enabled)	Google terms / SCCs
SMTP email provider	Transactional email	Per configured SMTP provider terms / SCCs where applicable

Transfer necessity, safeguards, and sub-subprocessor treatment should be documented in the customer DPA and transfer impact assessment.

10. Subprocessor change process

1. **Public register** maintained at <https://triagecounsel.com/security/subprocessors> with last-updated date.
2. **Material changes** (new subprocessors or material change in processing purpose/location) updated on the public page.
3. **Enterprise customers** with executed DPAs receive advance notice per contract terms (typically **30 days** before a new subprocessor processes customer personal data, unless otherwise agreed).
4. **Objection rights** as set out in the customer DPA apply where applicable.

11. Contact details

Purpose	Contact
Privacy / DPA / diligence inquiries	privacy@triagecounsel.com
Security questionnaires	privacy@triagecounsel.com (subject: Security Review)
General support	Via https://triagecounsel.com/contact

Public policies	Privacy: https://triagecounsel.com/privacy · Security: https://triagecounsel.com/security · Subprocessors: https://triagecounsel.com/security/subprocessors
------------------------	---

Registered legal entity name and address will be provided in the executed DPA and on the Privacy Policy upon completion of company formation.

This annex is provided for customer diligence. It should be read together with the executed DPA and does not replace legal counsel review.